

**Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

Факультет безопасности информационных технологий

Дисциплина:

«Технология обнаружения уязвимостей в автоматизированных системах»

ОТЧЕТ ПО CVSS Score

Выполнили:

Доан Тхи Хоай Тхыонг, студентка группы N3445



(подпись)

(подпись)

Проверил:

к.т.н., доц., Менщиков Александр Алексеевич

(отметка о выполнении)

(подпись)

Санкт-Петербург

2025 г.

1. Вариант задания

Уязвимость в веб-приложении, эксплуатируемая путем отправки запроса от имени неавторизованного пользователя. Она позволяет атакующему читать произвольные файлы на файловой системе.

2. Ход работы

Оценка v4 (CVSS-B): 8.7 / High

Вектор v4: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

Почему именно так (по компонентам вектора):

- AV:N (Attack Vector—Network). Эксплуатация идёт через веб-запрос к приложению по сети.
- AC:L (Attack Complexity—Low). Достаточно сформировать специальный HTTP-запрос; редких условий/сложной подготовки не требуется.
- AT:N (Attack Requirements—None). Нет дополнительных внешних условий (например, нахождения «в пути» и т. п.).
- PR:N (Privileges Required—None). Атакующий неавторизован (по условию задания).
- UI:N (User Interaction—None). Действий со стороны пользователя не требуется — достаточно входящего запроса.
- VC:H (Vulnerable System Confidentiality—High). Возможность читать произвольные файлы на сервере — это компрометация конфиденциальности на высоком уровне.
- VI:N / VA:N (Integrity/Availability—None). По условию доступ только на чтение: целостность и доступность не затрагиваются.
- SC:N / SI:N / SA:N (Subsequent System Impacts—None). По описанию затронута только уязвимая система; влияние на последующие системы не заявлено.

Проверка балла. Для точно такого же базового вектора в официальных примерах FIRST указан Base Score = 8.7 (см. документ «CVSS v4.0 Examples»).

Примечания.

Это базовая оценка (CVSS-B). Если бы сценарий требовал хотя бы низких привилегий (PR:L) или имел доп. условия (AT:P), балл снизился бы. Методика и калькулятор — у FIRST (спецификация, юзер-гайд, калькулятор).



Common Vulnerability Scoring System Version 4.0 Calculator

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

CVSS v4.0 Score: **8.7** / **High** ⊕

Exploitability Metrics			
Attack Vector (AV):	<input checked="" type="button" value="Network (N)"/>	Adjacent (A)	Local (L)
Attack Complexity (AC):	<input checked="" type="button" value="Low (L)"/>	High (H)	
Attack Requirements (AT):	<input checked="" type="button" value="None (N)"/>	Present (P)	
Privileges Required (PR):	<input checked="" type="button" value="None (N)"/>	Low (L)	High (H)
User Interaction (UI):	<input checked="" type="button" value="None (N)"/>	Passive (P)	Active (A)

Vulnerable System Impact Metrics		
Confidentiality (VC):	<input checked="" type="button" value="High (H)"/>	Low (L)
Integrity (VI):	High (H)	<input checked="" type="button" value="None (N)"/>
Availability (VA):	High (H)	<input checked="" type="button" value="None (N)"/>

Subsequent System Impact Metrics		
Confidentiality (SC):	High (H)	<input checked="" type="button" value="None (N)"/>
Integrity (SI):	High (H)	<input checked="" type="button" value="None (N)"/>
Availability (SA):	High (H)	<input checked="" type="button" value="None (N)"/>

Рисунок 1 - CVSS